

Table 1: Primary Functional Categories of Security Skills

ID	Primary Functional Category	What It Covers	Count
PFC-01	Source Code Vulnerability Detection	Reviews first-party source code for injection, authentication, cryptographic, memory, and logic flaws using OWASP/CWE-style audits or scanners; excludes dependency and infrastructure checks.	1,675
PFC-02	Dependency & Supply-Chain Security	Examines third-party dependencies for known CVEs, malicious or typosquatted packages, SBOM/provenance risks, license issues, and lockfile integrity.	506
PFC-03	Secrets & Credential Exposure Detection	Detects hardcoded or leaked keys, tokens, and passwords in source code or Git history, with supporting triage and rotation workflows.	163
PFC-04	Infrastructure, Cloud & Container Security Posture	Checks IaC, containers, cloud environments, CI/CD pipelines, and repository settings for security misconfigurations and hardening issues.	492
PFC-05	Web & API Application Security Testing	Actively tests running web applications and APIs through DAST, endpoint fuzzing, IDOR/SSRF/XSS probing, and authentication-flow attacks.	1,181
PFC-06	Offensive Security & Exploitation	Covers penetration testing, reconnaissance, privilege escalation, exploitation, post-exploitation, exploit development, CTFs, and bug-bounty workflows.	823
PFC-07	Smart Contract & Blockchain Security	Audits smart contracts and blockchain protocols for reentrancy, economic attacks, chain-specific vulnerabilities, and DeFi risks.	179
PFC-08	AI/LLM & Agent Security	Assesses prompt injection, jailbreaks, OWASP LLM risks, agent/tool permissions, MCP configurations, and model supply-chain security.	396
PFC-09	Threat Modeling & Security Design Review	Analyzes architectures and data flows using threat models, trust boundaries, and attack trees to derive threats, abuse cases, and security requirements.	147
PFC-10	Compliance, Governance & Standards Auditing	Assesses security-control gaps and evidence against standards and regulations such as SOC 2, PCI DSS, HIPAA, GDPR, NIST, CIS, and ISO 27001.	157
PFC-11	Vulnerability Management & Triage	Prioritizes existing findings using CVE/CVSS/EPSS data, monitoring, deduplication, false-positive triage, patch planning, and reporting; excludes initial discovery.	432
PFC-12	Malware, Threat Detection, IR & Forensics	Covers malware and backdoor analysis, YARA/IOC detection, digital forensics, incident response, threat hunting, and SOC workflows.	776
PFC-13	Secure Development Guidance & Remediation	Provides secure-coding, hardening, and remediation guidance for known vulnerability classes; focuses on prevention and fixing rather than discovery.	36
PFC-14	Binary, Reverse Engineering & Memory Safety	Uses reverse engineering, instrumentation, sanitizers, and fuzzing to analyze binaries, firmware, protocols, and memory-corruption vulnerabilities.	210
PFC-15	Mobile Application Security	Assesses Android and iOS applications through MASVS review, pinning/root/jailbreak bypass, component and deep-link testing, and static/dynamic analysis.	136
PFC-16	Network & Protocol Security Assessment	Assesses services, TLS/certificates, wireless and network protocols, firewalls/WAFs, and DNS/email security posture.	169